Vulnerability Scan Report

Target	Generated	Ports scanned
`127.0.0.1`	2026-10-16T09:44:32Z	7 `(21,2121,2375,6379,8080,8443,11211)`
Open services	**Duration**	**Scanner**
7	4.41 s	vulnscan 0.1.0

1. Executive summary

The purpose of this scan was to assess exposed network services on the listed targets. 25 finding(s) were identified across 7 open service(s) on 1 target(s). The table below counts each finding by its severity; the sections that follow group the detail by the same bands, highest risk first.

Vulnerability risk	Unique count
Critical vulnerability	5
High vulnerability	1
Medium vulnerability	4
Low vulnerability	11
Informational vulnerability	4

2. Scan results



25 finding(s). Click a severity to filter.

3. Methodology

Targets 127.0.0.1 were probed on 7 TCP ports (21,2121,2375,6379,8080,8443,11211) using async TCP connect scan with banner, TLS and HTTP probing. The scan runs in two phases: an availability phase that establishes which ports are reachable, and an assessment phase that probes each open port for its banner, TLS certificate and HTTP response, then applies the checks behind the findings in section 4. Checks cover exposed management and database services, anonymous access, TLS certificate and protocol weaknesses, HTTP

security-header configuration, and version fingerprints matched against known CVEs. No exploitation, authentication attempts or denial-of-service testing were performed; results reflect the state visible from the scan source at 2026-10-16T09:44:28Z

4. Findings

Critical severity vulnerability

5 finding(s). Critical vulnerabilities require immediate attention. They are relatively easy for attackers to exploit and may provide them with full control of the affected services.

VS-0001 **Critical** **confidence: certain**

vsftpd 2.3.4 backdoor (CVE-2011-2523)

`CWE-912` `CVE-2011-2523` `VS-CVE-2011-2523`

Affected asset

`127.0.0.1:2121/tcp · status open`

What was found

The banner identifies vsftpd 2.3.4, the release shipped with a deliberate backdoor that opens a shell on a non-standard port when the username contains ':)' .

Impact

Trivial remote code execution as the FTP server user.

Evidence

```
Banner: '220 (vsFTPD 2.3.4)'
```

Recommendation

Reinstall a current vsftpd release immediately and audit the host for signs of compromise.

References

https://nvd.nist.gov/vuln/detail/CVE-2011-2523

VS-0002 **Critical** **confidence: firm**

Docker daemon API exposed without TLS

`CWE-306` `VS-EXP-DOCKER`

Affected asset

`127.0.0.1:2375/tcp · status open`

What was found

The Docker daemon API is reachable over plain HTTP on port 2375. Anyone who can reach it fully controls the Docker daemon on this host.

Impact

Remote code execution: an attacker can start a privileged container, mount the host filesystem, and take over the machine.

Evidence

```
Port 2375/tcp is open and identified as http.
```

Recommendation

Disable the plain-HTTP Docker socket (-H fd:// without tcp:// binding), require TLS on 2376, and firewall the port.

References

https://cwe.mitre.org/data/definitions/306.html

VS-0003 **Critical** confidence: certain

Docker daemon API responds over HTTP

`CWE-306` `VS-HTTP-DOCKER-VERSION`

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

The Docker engine API answered an unauthenticated request on this port.

Impact

Remote code execution: containers, images and volumes are fully controllable by anyone who can reach the API.

Evidence

```
GET http://127.0.0.1:2375/version → 200; body: '<!DOCTYPE HTML>\n<html lang="en">\n<head>\n<meta charset="utf-8">\n<style type="text/css">\n:root {\ncolor-scheme: light dark;\n}\n</style>\n<title>Directory listing for /</title>\n</head>\n<body>\n<h1>Directory listing for /</h1>\n<hr>\n<ul>\n<li><a href=".freebuff/">.freebuff/</a></li>\n<li><a href="out/">out/</a'
```

Recommendation

Remove the tcp:// Docker socket binding; keep the API on a UNIX socket with TLS client auth if remote access is needed.

References

https://cwe.mitre.org/data/definitions/306.html

VS-0004 **Critical** **confidence: certain**

Redis exposed without authentication

`CWE-306` `VS-EXP-REDIS-NOAUTH`

Affected asset

`127.0.0.1:6379/tcp · status open`

What was found

The INFO command returned server details without requiring authentication, confirming that this Redis instance accepts commands from unauthenticated clients.

Impact

Full read and write access to cached data, session tokens and job queues. Crafted payloads can lead to remote code execution via CONFIG SET and module loading.

Evidence

```
INFO server response (no AUTH required): '#
Server\r\nredis_version:7.2.4\r\nredis_mode:standalone\r\nresponse:2'
```

Recommendation

Set 'requirepass' (or ACL users), bind Redis to trusted interfaces only, and firewall port 6379.

References

https://cwe.mitre.org/data/definitions/306.html
https://redis.io/docs/latest/operate/oss_and_stack/management/security/

VS-0005 **Critical** **confidence: certain**

Memcached exposed without authentication

`CWE-306` `VS-EXP-MEMCACHED-NOAUTH`

Affected asset

`127.0.0.1:11211/tcp · status open`

What was found

The memcached stats command returned server statistics without authentication, confirming unauthenticated access.

Impact

Read/write access to cached objects (sessions, tokens), plus historical use of memcached for UDP amplification DDoS.

Evidence

```
stats response: 'STAT pid 4242\r\nSTAT version 1.6.9\r\nSTAT curr_items 1\r\nEND'
```

Recommendation

Disable UDP listeners (-U 0), bind to localhost, set '-A' access control, and firewall port 11211.

References

https://cwe.mitre.org/data/definitions/306.html

High severity vulnerability

1 finding(s). High severity vulnerabilities are often harder to exploit and may not provide the same access to affected services.

VS-0006 High confidence: certain

Anonymous FTP login allowed

CWE-22 CWE-306 VS-FTP-ANON

Affected asset

`127.0.0.1:2121/tcp · status open`

What was found

The FTP server accepted an anonymous login, letting any unauthenticated client list and transfer files.

Impact

Unauthorized read (and on misconfigured sites, write) access to every file in the public tree, including backups or credentials left there.

Evidence

```
USER anonymous → server replied: '220 (vsFTPD 2.3.4)\r\n331 Please specify the password.\r\n230
Login successful.\r\n'
```

Recommendation

Set 'anon_enable=NO' in the FTP configuration, or restrict anonymous accounts to a read-only empty jail.

References

https://cwe.mitre.org/data/definitions/306.html

Medium severity vulnerability

4 finding(s). Medium severity vulnerabilities often provide information to attackers that may assist them in mounting subsequent attacks. Fix them in a timely manner.

VS-0007 **Medium** confidence: certain

Web service on port 2375 is missing Content-Security-Policy header

`CWE-693` `VS-HTTP-CSP`

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

The response has no Content-Security-Policy, leaving cross-site scripting defences to browser defaults.

Impact

Injected scripts execute freely, turning any XSS into full account takeover.

Evidence

```
GET / http://127.0.0.1:2375 returned 200 without a 'content-security-policy' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Define a CSP that restricts script sources and disallows inline script; start with report-only mode and tighten.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0008 **Medium** confidence: certain

Web service on port 8080 is missing Content-Security-Policy header

`CWE-693` `VS-HTTP-CSP`

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

The response has no Content-Security-Policy, leaving cross-site scripting defences to browser defaults.

Impact

Injected scripts execute freely, turning any XSS into full account takeover.

Evidence

```
GET / http://127.0.0.1:8080 returned 200 without a 'content-security-policy' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Define a CSP that restricts script sources and disallows inline script; start with report-only mode and tighten.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0009 **Medium** confidence: certain

Web service on port 8443 is missing Content-Security-Policy header

`CWE-693` `VS-HTTP-CSP`

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

The response has no Content-Security-Policy, leaving cross-site scripting defences to browser defaults.

Impact

Injected scripts execute freely, turning any XSS into full account takeover.

Evidence

```
GET / https://127.0.0.1:8443 returned 200 without a 'content-security-policy' header. Response headers: connection, content-length, content-type, server.
```

Recommendation

Define a CSP that restricts script sources and disallows inline script; start with report-only mode and tighten.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0010 **Medium** confidence: certain

Web service on port 8443 is missing HTTP Strict Transport Security (HSTS) header

`CWE-319` `VS-HTTP-HSTS`

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

The HTTPS response does not set Strict-Transport-Security, so browsers will still honour plain-HTTP requests to this host.

Impact

An attacker can strip the connection down to HTTP and capture credentials or session cookies (SSL stripping).

Evidence

```
GET / https://127.0.0.1:8443 returned 200 without a 'strict-transport-security' header. Response headers: connection, content-length, content-type, server.
```

Recommendation

Send 'Strict-Transport-Security: max-age=31536000; includeSubDomains' on all HTTPS responses.

References

https://cwe.mitre.org/data/definitions/319.html

Low severity vulnerability

11 finding(s). Low severity vulnerabilities do not need to be patched immediately and can be resolved during the next maintenance window.

VS-0011 **Low** **confidence: certain**

FTP credentials sent in cleartext

`CWE-319` `VS-FTP-CLEARTEXT`

Affected asset

`127.0.0.1:21/tcp · status open`

What was found

The FTP service exchanges usernames and passwords without encryption (no TLS observed).

Impact

Credentials can be captured by anyone able to observe traffic on the network path.

Evidence

```
Port 21 open. Banner: '220 Multicraft 2.5.0 FTP server'
```

Recommendation

Require FTPS (explicit TLS) or replace FTP with SFTP.

References

https://cwe.mitre.org/data/definitions/319.html

VS-0012 **Low** **confidence: certain**

Server version disclosed in HTTP header (SimpleHTTP/0.6 Python/3.14.6)

`CWE-200` `VS-HTTP-SERVER-VERSION`

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

The Server header reveals the exact web server software and version, removing the guessing an attacker would otherwise do when matching CVEs.

Impact

Targeted exploitation of version-specific vulnerabilities.

Evidence

```
Server: 'SimpleHTTP/0.6 Python/3.14.6'
```

Recommendation

Suppress version information (e.g. 'server_tokens off;' in nginx, 'ServerTokens Prod' in Apache).

References

https://cwe.mitre.org/data/definitions/200.html

VS-0013 Low confidence: certain

Web service on port 2375 is missing X-Content-Type-Options header

CWE-693 VS-HTTP-XCTO

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

The response omits X-Content-Type-Options: nosniff, so browsers may guess the content type of responses.

Impact

MIME-sniffing attacks can turn an uploaded file or text response into active script in the page's origin.

Evidence

```
GET / http://127.0.0.1:2375 returned 200 without a 'x-content-type-options' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Send 'X-Content-Type-Options: nosniff' on every response.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0014 **Low** **confidence: certain**

Web service on port 2375 is missing X-Frame-Options / frame-ancestors protection

`CWE-1021` `VS-HTTP-XFO`

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

The response can be framed by third-party pages because neither X-Frame-Options nor a frame-ancestors CSP directive is set.

Impact

Clickjacking: attackers overlay the page to trick users into clicking controls they cannot see.

Evidence

```
GET / http://127.0.0.1:2375 returned 200 without a 'x-frame-options' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Set 'X-Frame-Options: DENY' (or SAMEORIGIN) and/or a 'frame-ancestors' CSP directive.

References

https://cwe.mitre.org/data/definitions/1021.html

VS-0015 **Low** **confidence: certain**

Server version disclosed in HTTP header (SimpleHTTP/0.6 Python/3.14.6)

`CWE-200` `VS-HTTP-SERVER-VERSION`

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

The Server header reveals the exact web server software and version, removing the guessing an attacker would otherwise do when matching CVEs.

Impact

Targeted exploitation of version-specific vulnerabilities.

Evidence

```
Server: 'SimpleHTTP/0.6 Python/3.14.6'
```

Recommendation

Suppress version information (e.g. 'server_tokens off;' in nginx, 'ServerTokens Prod' in Apache).

References

https://cwe.mitre.org/data/definitions/200.html

VS-0016 Low confidence: certain

Web service on port 8080 is missing X-Content-Type-Options header

CWE-693 VS-HTTP-XCTO

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

The response omits X-Content-Type-Options: nosniff, so browsers may guess the content type of responses.

Impact

MIME-sniffing attacks can turn an uploaded file or text response into active script in the page's origin.

Evidence

```
GET / http://127.0.0.1:8080 returned 200 without a 'x-content-type-options' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Send 'X-Content-Type-Options: nosniff' on every response.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0017 Low confidence: certain

Web service on port 8080 is missing X-Frame-Options / frame-ancestors protection

CWE-1021 VS-HTTP-XFO

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

The response can be framed by third-party pages because neither X-Frame-Options nor a frame-ancestors CSP directive is set.

Impact

Clickjacking: attackers overlay the page to trick users into clicking controls they cannot see.

Evidence

```
GET / http://127.0.0.1:8080 returned 200 without a 'x-frame-options' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Set 'X-Frame-Options: DENY' (or SAMEORIGIN) and/or a 'frame-ancestors' CSP directive.

References

https://cwe.mitre.org/data/definitions/1021.html

VS-0018 Low confidence: certain

Server version disclosed in HTTP header (TestWeb/1.2)

CWE-200 VS-HTTP-SERVER-VERSION

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

The Server header reveals the exact web server software and version, removing the guessing an attacker would otherwise do when matching CVEs.

Impact

Targeted exploitation of version-specific vulnerabilities.

Evidence

```
Server: 'TestWeb/1.2'
```

Recommendation

Suppress version information (e.g. 'server_tokens off;' in nginx, 'ServerTokens Prod' in Apache).

References

https://cwe.mitre.org/data/definitions/200.html

VS-0019 Low confidence: certain

Web service on port 8443 is missing X-Content-Type-Options header

CWE-693 VS-HTTP-XCTO

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

The response omits X-Content-Type-Options: nosniff, so browsers may guess the content type of responses.

Impact

MIME-sniffing attacks can turn an uploaded file or text response into active script in the page's origin.

Evidence

```
GET / https://127.0.0.1:8443 returned 200 without a 'x-content-type-options' header. Response headers: connection, content-length, content-type, server.
```

Recommendation

Send 'X-Content-Type-Options: nosniff' on every response.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0020 Low confidence: certain

Web service on port 8443 is missing X-Frame-Options / frame-ancestors protection

CWE-1021 VS-HTTP-XFO

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

The response can be framed by third-party pages because neither X-Frame-Options nor a frame-ancestors CSP directive is set.

Impact

Clickjacking: attackers overlay the page to trick users into clicking controls they cannot see.

Evidence

```
GET / https://127.0.0.1:8443 returned 200 without a 'x-frame-options' header. Response headers: connection, content-length, content-type, server.
```

Recommendation

Set 'X-Frame-Options: DENY' (or SAMEORIGIN) and/or a 'frame-ancestors' CSP directive.

References

https://cwe.mitre.org/data/definitions/1021.html

VS-0021 Low confidence: certain

Self-signed TLS certificate

CWE-295 VS-TLS-SELF-SIGNED

Affected asset

`127.0.0.1:8443/tcp · status open`

What was found

The certificate is signed by its own subject rather than a trusted certificate authority, so clients cannot establish trust in the server's identity.

Impact

Browsers warn users, training them to click through warnings; man-in-the-middle attacks become indistinguishable from the legitimate certificate.

Evidence

```
Subject 'testapp.local' == issuer 'testapp.local'.
```

Recommendation

Issue the certificate from a trusted CA (Let's Encrypt is free) or add the internal CA to trusted stores.

References

https://cwe.mitre.org/data/definitions/295.html

Informational severity vulnerability

4 finding(s). Informational items are observations worth reviewing, not immediate risks.

VS-0022 **Informational** **confidence: certain**

Web service on port 2375 is missing Referrer-Policy header

`CWE-200` `VS-HTTP-REFPOL`

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

Without Referrer-Policy, full URLs (including query strings and session tokens) leak to third-party sites through the Referer header.

Impact

Disclosure of URLs, tokens or identifiers to external origins.

Evidence

```
GET / http://127.0.0.1:2375 returned 200 without a 'referrer-policy' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Send 'Referrer-Policy: strict-origin-when-cross-origin' or stricter.

References

https://cwe.mitre.org/data/definitions/200.html

VS-0023 **Informational** **confidence: certain**

Web service on port 8080 served over plaintext HTTP

`CWE-319` `VS-HTTP-CLEARTEXT`

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

The service answers plain HTTP with no TLS listener observed, so all request and response traffic crosses the network unencrypted.

Impact

Credentials, cookies and page content are readable and modifiable by anyone on the path.

Evidence

```
HTTP GET http://127.0.0.1:8080/ → 200 OK (no TLS).
```

Recommendation

Terminate TLS in front of the service and redirect HTTP to HTTPS.

References

https://cwe.mitre.org/data/definitions/319.html

VS-0024 **Informational** **confidence: certain**

Web service on port 8080 is missing Referrer-Policy header

`CWE-200` `VS-HTTP-REFPOL`

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

Without Referrer-Policy, full URLs (including query strings and session tokens) leak to third-party sites through the Referer header.

Impact

Disclosure of URLs, tokens or identifiers to external origins.

Evidence

```
GET / http://127.0.0.1:8080 returned 200 without a 'referrer-policy' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Send 'Referrer-Policy: strict-origin-when-cross-origin' or stricter.

References

https://cwe.mitre.org/data/definitions/200.html

VS-0025 **Informational** **confidence: certain**

Web service on port 8443 is missing Referrer-Policy header

`CWE-200` `VS-HTTP-REFPOL`

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

Without Referrer-Policy, full URLs (including query strings and session tokens) leak to third-party sites through the Referer header.

Impact

Disclosure of URLs, tokens or identifiers to external origins.

Evidence

```
GET / https://127.0.0.1:8443 returned 200 without a 'referrer-policy' header. Response headers: connection, content-length, content-type, server.
```

Recommendation

Send 'Referrer-Policy: strict-origin-when-cross-origin' or stricter.

References

https://cwe.mitre.org/data/definitions/200.html

Detailed findings

VS-0001 **Critical** **confidence: certain**

vsftpd 2.3.4 backdoor (CVE-2011-2523)

`CWE-912` `CVE-2011-2523` `VS-CVE-2011-2523`

Affected asset

`127.0.0.1:2121/tcp · status open`

What was found

The banner identifies vsftpd 2.3.4, the release shipped with a deliberate backdoor that opens a shell on a non-standard port when the username contains ':)' .

Impact

Trivial remote code execution as the FTP server user.

Evidence

```
Banner: '220 (vsFTPD 2.3.4)'
```

Recommendation

Reinstall a current vsftpd release immediately and audit the host for signs of compromise.

References

https://nvd.nist.gov/vuln/detail/CVE-2011-2523

VS-0002 **Critical** confidence: firm

Docker daemon API exposed without TLS

`CWE-306` `VS-EXP-DOCKER`

Affected asset

`127.0.0.1:2375/tcp · status open`

What was found

The Docker daemon API is reachable over plain HTTP on port 2375. Anyone who can reach it fully controls the Docker daemon on this host.

Impact

Remote code execution: an attacker can start a privileged container, mount the host filesystem, and take over the machine.

Evidence

```
Port 2375/tcp is open and identified as http.
```

Recommendation

Disable the plain-HTTP Docker socket (-H fd:// without tcp:// binding), require TLS on 2376, and firewall the port.

References

https://cwe.mitre.org/data/definitions/306.html

VS-0003 **Critical** confidence: certain

Docker daemon API responds over HTTP

`CWE-306` `VS-HTTP-DOCKER-VERSION`

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

The Docker engine API answered an unauthenticated request on this port.

Impact

Remote code execution: containers, images and volumes are fully controllable by anyone who can reach the API.

Evidence

```
GET http://127.0.0.1:2375/version → 200; body: '<!DOCTYPE HTML>\n<html lang="en">\n<head>\n<meta charset="utf-8">\n<style type="text/css">\n:root {\ncolor-scheme: light dark;\n}\n</style>\n<title>Directory listing for /</title>\n</head>\n<body>\n<h1>Directory listing for /</h1>\n<hr>\n<ul>\n<li><a href=".freebuff/">.freebuff/</a></li>\n<li><a href="out/">out/</a'
```

Recommendation

Remove the tcp:// Docker socket binding; keep the API on a UNIX socket with TLS client auth if remote access is needed.

References

https://cwe.mitre.org/data/definitions/306.html

VS-0004 **Critical** **confidence: certain**

Redis exposed without authentication

`CWE-306` `VS-EXP-REDIS-NOAUTH`

Affected asset

`127.0.0.1:6379/tcp · status open`

What was found

The INFO command returned server details without requiring authentication, confirming that this Redis instance accepts commands from unauthenticated clients.

Impact

Full read and write access to cached data, session tokens and job queues. Crafted payloads can lead to remote code execution via CONFIG SET and module loading.

Evidence

```
INFO server response (no AUTH required): '#
Server\r\nredis_version:7.2.4\r\nredis_mode:standalone\r\nresponse:2'
```

Recommendation

Set 'requirepass' (or ACL users), bind Redis to trusted interfaces only, and firewall port 6379.

References

https://cwe.mitre.org/data/definitions/306.html
https://redis.io/docs/latest/operate/oss_and_stack/management/security/

VS-0005 **Critical** **confidence: certain**

Memcached exposed without authentication

`CWE-306` `VS-EXP-MEMCACHED-NOAUTH`

Affected asset

`127.0.0.1:11211/tcp · status open`

What was found

The memcached stats command returned server statistics without authentication, confirming unauthenticated access.

Impact

Read/write access to cached objects (sessions, tokens), plus historical use of memcached for UDP amplification DDoS.

Evidence

```
stats response: 'STAT pid 4242\r\nSTAT version 1.6.9\r\nSTAT curr_items 1\r\nEND'
```

Recommendation

Disable UDP listeners (-U 0), bind to localhost, set '-A' access control, and firewall port 11211.

References

https://cwe.mitre.org/data/definitions/306.html

VS-0006 High confidence: certain

Anonymous FTP login allowed

CWE-22 CWE-306 VS-FTP-ANON

Affected asset

`127.0.0.1:2121/tcp · status open`

What was found

The FTP server accepted an anonymous login, letting any unauthenticated client list and transfer files.

Impact

Unauthorized read (and on misconfigured sites, write) access to every file in the public tree, including backups or credentials left there.

Evidence

```
USER anonymous → server replied: '220 (vsFTPD 2.3.4)\r\n331 Please specify the password.\r\n230
Login successful.\r\n'
```

Recommendation

Set 'anon_enable=NO' in the FTP configuration, or restrict anonymous accounts to a read-only empty jail.

References

https://cwe.mitre.org/data/definitions/306.html

VS-0007 **Medium** confidence: certain

Web service on port 2375 is missing Content-Security-Policy header

`CWE-693` `VS-HTTP-CSP`

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

The response has no Content-Security-Policy, leaving cross-site scripting defences to browser defaults.

Impact

Injected scripts execute freely, turning any XSS into full account takeover.

Evidence

```
GET / http://127.0.0.1:2375 returned 200 without a 'content-security-policy' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Define a CSP that restricts script sources and disallows inline script; start with report-only mode and tighten.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0008 **Medium** confidence: certain

Web service on port 8080 is missing Content-Security-Policy header

`CWE-693` `VS-HTTP-CSP`

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

The response has no Content-Security-Policy, leaving cross-site scripting defences to browser defaults.

Impact

Injected scripts execute freely, turning any XSS into full account takeover.

Evidence

```
GET / http://127.0.0.1:8080 returned 200 without a 'content-security-policy' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Define a CSP that restricts script sources and disallows inline script; start with report-only mode and tighten.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0009 **Medium** confidence: certain

Web service on port 8443 is missing Content-Security-Policy header

`CWE-693` `VS-HTTP-CSP`

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

The response has no Content-Security-Policy, leaving cross-site scripting defences to browser defaults.

Impact

Injected scripts execute freely, turning any XSS into full account takeover.

Evidence

```
GET / https://127.0.0.1:8443 returned 200 without a 'content-security-policy' header. Response headers: connection, content-length, content-type, server.
```

Recommendation

Define a CSP that restricts script sources and disallows inline script; start with report-only mode and tighten.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0010 **Medium** confidence: certain

Web service on port 8443 is missing HTTP Strict Transport Security (HSTS) header

`CWE-319` `VS-HTTP-HSTS`

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

The HTTPS response does not set Strict-Transport-Security, so browsers will still honour plain-HTTP requests to this host.

Impact

An attacker can strip the connection down to HTTP and capture credentials or session cookies (SSL stripping).

Evidence

```
GET / https://127.0.0.1:8443 returned 200 without a 'strict-transport-security' header. Response headers: connection, content-length, content-type, server.
```

Recommendation

Send 'Strict-Transport-Security: max-age=31536000; includeSubDomains' on all HTTPS responses.

References

https://cwe.mitre.org/data/definitions/319.html

VS-0011 Low confidence: certain

FTP credentials sent in cleartext

CWE-319 VS-FTP-CLEARTEXT

Affected asset

`127.0.0.1:21/tcp · status open`

What was found

The FTP service exchanges usernames and passwords without encryption (no TLS observed).

Impact

Credentials can be captured by anyone able to observe traffic on the network path.

Evidence

```
Port 21 open. Banner: '220 Multicraft 2.5.0 FTP server'
```

Recommendation

Require FTPS (explicit TLS) or replace FTP with SFTP.

References

https://cwe.mitre.org/data/definitions/319.html

VS-0012 Low confidence: certain

Server version disclosed in HTTP header (SimpleHTTP/0.6 Python/3.14.6)

CWE-200 VS-HTTP-SERVER-VERSION

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

The Server header reveals the exact web server software and version, removing the guessing an attacker would otherwise do when matching CVEs.

Impact

Targeted exploitation of version-specific vulnerabilities.

Evidence

```
Server: 'SimpleHTTP/0.6 Python/3.14.6'
```

Recommendation

Suppress version information (e.g. 'server_tokens off;' in nginx, 'ServerTokens Prod' in Apache).

References

https://cwe.mitre.org/data/definitions/200.html

VS-0013 Low confidence: certain

Web service on port 2375 is missing X-Content-Type-Options header

CWE-693 VS-HTTP-XCTO

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

The response omits X-Content-Type-Options: nosniff, so browsers may guess the content type of responses.

Impact

MIME-sniffing attacks can turn an uploaded file or text response into active script in the page's origin.

Evidence

```
GET / http://127.0.0.1:2375 returned 200 without a 'x-content-type-options' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Send 'X-Content-Type-Options: nosniff' on every response.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0014 Low confidence: certain

Web service on port 2375 is missing X-Frame-Options / frame-ancestors protection

CWE-1021 VS-HTTP-XFO

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

The response can be framed by third-party pages because neither X-Frame-Options nor a frame-ancestors CSP directive is set.

Impact

Clickjacking: attackers overlay the page to trick users into clicking controls they cannot see.

Evidence

```
GET / http://127.0.0.1:2375 returned 200 without a 'x-frame-options' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Set 'X-Frame-Options: DENY' (or SAMEORIGIN) and/or a 'frame-ancestors' CSP directive.

References

https://cwe.mitre.org/data/definitions/1021.html

VS-0015 **Low** **confidence: certain**

Server version disclosed in HTTP header (SimpleHTTP/0.6 Python/3.14.6)

`CWE-200` `VS-HTTP-SERVER-VERSION`

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

The Server header reveals the exact web server software and version, removing the guessing an attacker would otherwise do when matching CVEs.

Impact

Targeted exploitation of version-specific vulnerabilities.

Evidence

```
Server: 'SimpleHTTP/0.6 Python/3.14.6'
```

Recommendation

Suppress version information (e.g. 'server_tokens off;' in nginx, 'ServerTokens Prod' in Apache).

References

https://cwe.mitre.org/data/definitions/200.html

VS-0016 Low confidence: certain

Web service on port 8080 is missing X-Content-Type-Options header

CWE-693 VS-HTTP-XCTO

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

The response omits X-Content-Type-Options: nosniff, so browsers may guess the content type of responses.

Impact

MIME-sniffing attacks can turn an uploaded file or text response into active script in the page's origin.

Evidence

```
GET / http://127.0.0.1:8080 returned 200 without a 'x-content-type-options' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Send 'X-Content-Type-Options: nosniff' on every response.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0017 Low confidence: certain

Web service on port 8080 is missing X-Frame-Options / frame-ancestors protection

CWE-1021 VS-HTTP-XFO

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

The response can be framed by third-party pages because neither X-Frame-Options nor a frame-ancestors CSP directive is set.

Impact

Clickjacking: attackers overlay the page to trick users into clicking controls they cannot see.

Evidence

```
GET / http://127.0.0.1:8080 returned 200 without a 'x-frame-options' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Set 'X-Frame-Options: DENY' (or SAMEORIGIN) and/or a 'frame-ancestors' CSP directive.

References

https://cwe.mitre.org/data/definitions/1021.html

VS-0018 **Low** **confidence: certain**

Server version disclosed in HTTP header (TestWeb/1.2)

`CWE-200` `VS-HTTP-SERVER-VERSION`

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

The Server header reveals the exact web server software and version, removing the guessing an attacker would otherwise do when matching CVEs.

Impact

Targeted exploitation of version-specific vulnerabilities.

Evidence

```
Server: 'TestWeb/1.2'
```

Recommendation

Suppress version information (e.g. 'server_tokens off;' in nginx, 'ServerTokens Prod' in Apache).

References

https://cwe.mitre.org/data/definitions/200.html

VS-0019 Low confidence: certain

Web service on port 8443 is missing X-Content-Type-Options header

CWE-693 VS-HTTP-XCTO

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

The response omits X-Content-Type-Options: nosniff, so browsers may guess the content type of responses.

Impact

MIME-sniffing attacks can turn an uploaded file or text response into active script in the page's origin.

Evidence

```
GET / https://127.0.0.1:8443 returned 200 without a 'x-content-type-options' header. Response headers: connection, content-length, content-type, server.
```

Recommendation

Send 'X-Content-Type-Options: nosniff' on every response.

References

https://cwe.mitre.org/data/definitions/693.html

VS-0020 Low confidence: certain

Web service on port 8443 is missing X-Frame-Options / frame-ancestors protection

CWE-1021 VS-HTTP-XFO

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

The response can be framed by third-party pages because neither X-Frame-Options nor a frame-ancestors CSP directive is set.

Impact

Clickjacking: attackers overlay the page to trick users into clicking controls they cannot see.

Evidence

```
GET / https://127.0.0.1:8443 returned 200 without a 'x-frame-options' header. Response headers: connection, content-length, content-type, server.
```

Recommendation

Set 'X-Frame-Options: DENY' (or SAMEORIGIN) and/or a 'frame-ancestors' CSP directive.

References

https://cwe.mitre.org/data/definitions/1021.html

VS-0021 **Low** **confidence: certain**

Self-signed TLS certificate

`CWE-295` `VS-TLS-SELF-SIGNED`

Affected asset

`127.0.0.1:8443/tcp · status open`

What was found

The certificate is signed by its own subject rather than a trusted certificate authority, so clients cannot establish trust in the server's identity.

Impact

Browsers warn users, training them to click through warnings; man-in-the-middle attacks become indistinguishable from the legitimate certificate.

Evidence

```
Subject 'testapp.local' == issuer 'testapp.local'.
```

Recommendation

Issue the certificate from a trusted CA (Let's Encrypt is free) or add the internal CA to trusted stores.

References

https://cwe.mitre.org/data/definitions/295.html

VS-0022 **Informational** **confidence: certain**

Web service on port 2375 is missing Referrer-Policy header

`CWE-200` `VS-HTTP-REFPOL`

Affected asset

`http://127.0.0.1:2375/ · status open`

What was found

Without Referrer-Policy, full URLs (including query strings and session tokens) leak to third-party sites through the Referer header.

Impact

Disclosure of URLs, tokens or identifiers to external origins.

Evidence

```
GET / http://127.0.0.1:2375 returned 200 without a 'referrer-policy' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Send 'Referrer-Policy: strict-origin-when-cross-origin' or stricter.

References

https://cwe.mitre.org/data/definitions/200.html

VS-0023 **Informational** **confidence: certain**

Web service on port 8080 served over plaintext HTTP

`CWE-319` `VS-HTTP-CLEARTEXT`

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

The service answers plain HTTP with no TLS listener observed, so all request and response traffic crosses the network unencrypted.

Impact

Credentials, cookies and page content are readable and modifiable by anyone on the path.

Evidence

```
HTTP GET http://127.0.0.1:8080/ → 200 OK (no TLS).
```

Recommendation

Terminate TLS in front of the service and redirect HTTP to HTTPS.

References

https://cwe.mitre.org/data/definitions/319.html

VS-0024 **Informational** **confidence: certain**

Web service on port 8080 is missing Referrer-Policy header

`CWE-200` `VS-HTTP-REFPOL`

Affected asset

`http://127.0.0.1:8080/ · status open`

What was found

Without Referrer-Policy, full URLs (including query strings and session tokens) leak to third-party sites through the Referer header.

Impact

Disclosure of URLs, tokens or identifiers to external origins.

Evidence

```
GET / http://127.0.0.1:8080 returned 200 without a 'referrer-policy' header. Response headers: content-length, content-type, date, server.
```

Recommendation

Send 'Referrer-Policy: strict-origin-when-cross-origin' or stricter.

References

https://cwe.mitre.org/data/definitions/200.html

VS-0025 **Informational** **confidence: certain**

Web service on port 8443 is missing Referrer-Policy header

`CWE-200` `VS-HTTP-REFPOL`

Affected asset

`https://127.0.0.1:8443/ · status open`

What was found

Without Referrer-Policy, full URLs (including query strings and session tokens) leak to third-party sites through the Referer header.

Impact

Disclosure of URLs, tokens or identifiers to external origins.

Evidence

```
GET / https://127.0.0.1:8443 returned 200 without a 'referrer-policy' header. Response headers: connection, content-length, content-type, server.
```

Recommendation

Send 'Referrer-Policy: strict-origin-when-cross-origin' or stricter.

References

https://cwe.mitre.org/data/definitions/200.html

5. Recommendations

Addressing the actions below in this order resolves the most findings with the least effort. The Vulns column counts affected findings and the Hosts column counts distinct services affected.

Remediation action	Severity	Vulns	Hosts
Define a CSP that restricts script sources and disallows inline script; start with report-only mode and tighten.	Medium	3	3
Suppress version information (e.g. 'server_tokens off;' in nginx, 'ServerTokens Prod' in Apache).	Low	3	3
Send 'X-Content-Type-Options: nosniff' on every response.	Low	3	3
Set 'X-Frame-Options: DENY' (or SAMEORIGIN) and/or a 'frame-ancestors' CSP directive.	Low	3	3
Send 'Referrer-Policy: strict-origin-when-cross-origin' or stricter.	Informational	3	3

Remediation action	Severity	Vulns	Hosts
Reinstall a current vsftpd release immediately and audit the host for signs of compromise.	Critical	1	1
Disable the plain-HTTP Docker socket (-H fd:// without tcp:// binding), require TLS on 2376, and firewall the port.	Critical	1	1
Remove the tcp:// Docker socket binding; keep the API on a UNIX socket with TLS client auth if remote access is needed.	Critical	1	1
Set 'requirepass' (or ACL users), bind Redis to trusted interfaces only, and firewall port 6379.	Critical	1	1
Disable UDP listeners (-U 0), bind to localhost, set '-A' access control, and firewall port 11211.	Critical	1	1
Set 'anon_enable=NO' in the FTP configuration, or restrict anonymous accounts to a read-only empty jail.	High	1	1
Send 'Strict-Transport-Security: max-age=31536000; includeSubDomains' on all HTTPS responses.	Medium	1	1
Require FTPS (explicit TLS) or replace FTP with SFTP.	Low	1	1
Issue the certificate from a trusted CA (Let's Encrypt is free) or add the internal CA to trusted stores.	Low	1	1
Terminate TLS in front of the service and redirect HTTP to HTTPS.	Informational	1	1

Appendix — observed services

Host	Port	Service	Product	TLS	Banner
`127.0.0.1`	`21`	`ftp`	—	—	`220 Multicraft 2.5.0 FTP server`
`127.0.0.1`	`2121`	`ftp/smtp`	vsFTPD 2.3.4	—	`220 (vsFTPD 2.3.4)`
`127.0.0.1`	`2375`	`http`	SimpleHTTP 0.6	—	
`127.0.0.1`	`6379`	`redis`	Redis 7.2.4	—	`# Server redis_version:7.2.4 redis_mode:standalone respon`
`127.0.0.1`	`8080`	`http`	SimpleHTTP 0.6	—	

Host	Port	Service	Product	TLS	Banner
127.0.0.1	8443	https	TestWeb 1.2	TLS TLSv1.3	
127.0.0.1	11211	memcached	Memcached 1.6.9	—	STAT pid 4242 STAT version 1.6.9 STAT curr_items 1 END